



NayaHR — Privacy Policy

DRAFT for legal review. Prepared as a working draft aligned to India's Digital Personal Data Protection Act, 2023 (DPDP Act). This is not legal advice — have it reviewed and finalised by qualified Indian legal counsel before publishing. Bracketed [...] items are facts to be filled at finalisation.

NayaHR Private Limited ("NayaHR", "we", "us", "our") Registered office: [Registered address], Pune, Maharashtra, India · CIN: [CIN] **Effective date:** [Effective date — set on publication] · **Last updated:** 28 July 2026

1. About this policy

NayaHR provides an AI-native HR & payroll platform (the "Service") to businesses in India. This Privacy Policy explains how we handle personal data.

We handle personal data in **two capacities**:

- As a **Data Fiduciary** — for the personal data of the people who create and administer a NayaHR account (business owners, HR administrators, billing contacts) and visitors to our website. We decide the purpose and means of this processing, and this policy governs it.
- As a **Data Processor** — for the personal data of a customer's employees that the customer uploads or enters into the Service (employee records, compensation, payroll, statutory identifiers). Here the **customer (the employer) is the Data Fiduciary** and decides how that data is used; we process it only on their instructions. That processing is governed by our **Data Processing Agreement (DPA)** with the customer, not by this policy. **If you are an employee of a NayaHR customer, please direct privacy questions to your employer in the first instance.**

2. Personal data we collect

Account & administrator users (we are the Fiduciary): - Identity & contact: name, work email, phone (optional), job title, employer/company name. - Authentication: credentials and identifiers managed by our auth provider (Clerk), including Google sign-in identifiers where used. - Billing: business billing contact and transaction records. We do **not** collect or store card numbers; fees are invoiced and paid by bank transfer or UPI. - Support & communications: messages you send us.

Employee data (we are the Processor, on the customer's instruction): - Employee identity & job data: name, email, department, location, manager, employment status, joining date. - Compensation & payroll: salary structure, payslip components, statutory deductions (PF, ESI, Professional Tax, TDS), loss-of-pay. - Payout & statutory identifiers: bank account number, IFSC, UPI ID, PAN, UAN.

Technical data (all users): - Usage and device/log data, and error diagnostics captured by our monitoring provider (Sentry). Session cookies set by our auth provider to keep you signed in.

3. How we use personal data & our lawful basis

We process personal data to: provide, secure and operate the Service; authenticate users; run HR and payroll workflows on the customer's behalf; process billing; provide support; monitor reliability and prevent abuse; and comply with law.

Under the DPDP Act, our lawful basis is: (a) the individual's **consent** where required; (b) **certain legitimate uses** permitted by the Act (e.g. where data is voluntarily provided, for employment purposes, and for compliance); and (c) for employee data, the **documented instructions of the customer** as Data Fiduciary. We do **not** sell personal data or use it for advertising.

4. AI features

The Service includes an AI assistant. To generate responses, relevant context may be sent to our AI provider (**Anthropic**) via its API. Per Anthropic's API terms, data submitted through the API is **not used to train its models**. We limit what is sent to what is needed to fulfil the request.

5. Sharing & sub-processors

We do not sell personal data. We share it only with service providers ("sub-processors") that help us run the Service, under contractual confidentiality and data-protection obligations:

Sub-processor	Purpose	Processing location
Neon	Database hosting	India (Mumbai) [CONFIRM once migrated]
Clerk	Authentication / sign-in	United States
Vercel	Application hosting / delivery	United States & global edge
Anthropic	AI assistant (API)	United States
GoDaddy	Business email	Global

We may also disclose data where required by law or to protect our rights, users, or the public.

6. Cross-border transfer & data residency

We host the primary customer database in **India (Mumbai)**. Some sub-processors above process limited data outside India. The DPDP Act permits such transfers except to countries restricted by the Government of India; we transfer only to providers under appropriate contractual safeguards.

7. Security

We apply technical and organisational safeguards including: strict per-customer data isolation using PostgreSQL Row-Level Security (enforced so the application cannot bypass it), encryption of data in transit (TLS), access controls and least-privilege roles, invitation-only access, audit logging of sensitive actions, and error/uptime monitoring. No system is perfectly secure, but we work to protect your data and to notify affected parties of breaches as required by law.

8. Retention

We retain account and employee data for as long as the customer's subscription is active. After termination, data is retained for a grace period of **30–90 days** to allow export and reactivation, after which it is permanently deleted, unless a longer period is required by law. Backups are purged on their normal cycle.

9. Your rights (Data Principals)

Subject to the DPDP Act, you have the right to: **access** a summary of your personal data and processing; **correction, completion and updating**; **erasure** where no longer needed; **grievance redressal**; and to **nominate** another individual to exercise your rights in the event of death or incapacity.

- **Account/administrator users:** contact us using Section 11 to exercise these rights.
- **Employees of a customer:** your employer controls your employee record — please raise requests with your employer, who we will assist as their processor.

We will respond within the timelines required by law. We may need to verify your identity before acting.

10. Children

The Service is a workplace tool intended for use by adults (employees) and is **not directed at children**. We do not knowingly process the personal data of children through the Service.

11. Grievance Officer & contact

For any question, request, or grievance regarding personal data:

Grievance Officer: Charu Tripathi **Email:** hello@nayahr.in **NayaHR Private Limited**, [Registered address], Pune, Maharashtra, India

12. Changes

We may update this policy from time to time. Material changes will be notified through the Service or by email, and the "Last updated" date will change.

13. Governing law

This policy is governed by the laws of India. Disputes are subject to the exclusive jurisdiction of the courts at **Pune, Maharashtra**.